

Plan de sécurisation IT

Goiran et Compagnie

Sécurité physique - Messagerie - Gestion des mots de passe - Accès sécurises

Sommaire

1. Sécurité physique & gestion des sauvegardes
2. Sécurité de la messagerie & Mailinblack
3. Gestion des mots de passe — KeePass
4. Accès personnalises aux postes de travail

Séparation physique du NAS

Isoler le NAS du serveur pour limiter les risques de perte simultanée

Situation actuelle - RISQUE

Le NAS et le serveur SRV-HV-01 sont dans le même local technique.

En cas de sinistre (incendie, inondation, vol), les deux équipements sont détruits simultanément.

La sauvegarde locale (NAS) est perdue en même temps que le serveur = perte totale des données on-site.

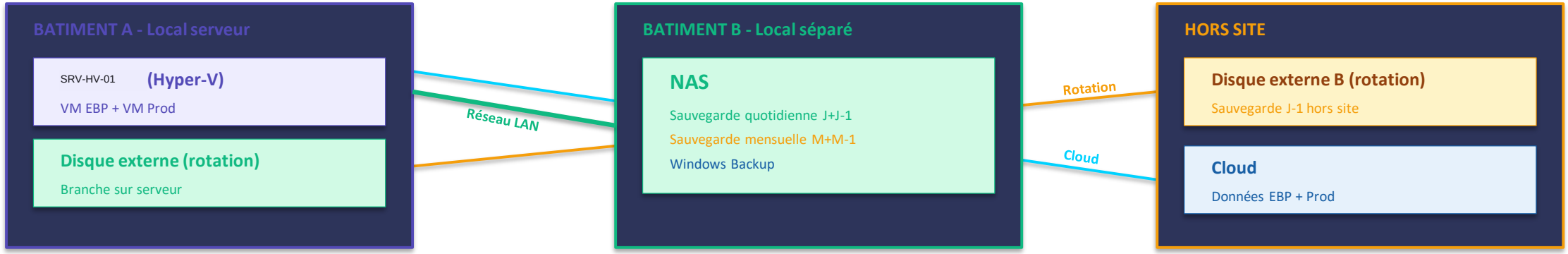
Recommandation - NAS dans un bâtiment sépare

Déplacer le NAS dans un bâtiment différant du serveur (ex : bureau administratif, local technique secondaire).

Avantages :
- Sinistre sur un bâtiment = l'autre bâtiment préserve
- Sauvegarde quotidienne toujours accessible

Le NAS reste sur le même réseau LAN, accessible par le serveur pour les sauvegardes automatiques.

Schéma : séparation physique



Rotation disques externes & disque Quadra supplémentaire

Renforcer la protection et libérer de l'espace serveur/cloud

Rotation de 2 disques externes

Principe

Deux disques durs externes identiques en rotation quotidienne

Fonctionnement

Disque A sur site (branche sur serveur, sauvegarde active)
Disque B hors site (domicile responsable / coffre / local distant)

Echange quotidien

Chaque matin : récupérer B, brancher B, emmener A hors site

Sécurité du disque

Chiffrement BitLocker sur les deux disques
Mot de passe fort stocke dans KeePass (voir Partie 3)

Confidentialité des disques externes

Chiffrement BitLocker

Chiffrement intégral du disque externe
Sans le mot de passe, le disque est illisible même en cas de vol

Etiquetage discret

Pas de mention 'Sauvegarde Goiran' sur le disque
Identification interne uniquement (Disque A / Disque B)

Procédure de perte

En cas de perte/vol d'un disque :
1. Signaler immédiatement au service IT
2. Changer le mot de passe BitLocker
3. Remplacer le disque

Disque supplémentaire dédié à Quadra

Constat

La suite Quadra (Bureau, Propreté, Paie) occupe un espace significatif sur le serveur et le cloud.
Les archives Quadra anciennes ne sont pas modifiées mais prennent de la place.

Proposition

Commander un disque dur externe supplémentaire dédie a l'archivage Quadra.
Déplacer les bases Quadra anciennes / archives sur ce disque dédie.

Bénéfices

- Libérer de l'espace sur F:\VData (serveur) et sur le Cloud
- Réduire le temps de sauvegarde quotidienne (moins de données a copier)
- Archives Quadra toujours accessibles en cas de besoin

Stockage recommande

Disque chiffre BitLocker, stocke dans le local NAS (Bâtiment B)
Sauvegarde mensuelle sur le NAS en complément

Mailinblack — Protection de la messagerie

Solution de filtrage des e-mails déjà déployée

Qu'est-ce que Mailinblack ?

Bouclier anti-spam / anti-phishing

Filtre tous les e-mails entrants AVANT qu'ils n'arrivent dans les boites mail

Protection en temps réel

Analyse chaque message : expéditeur, contenu, pièces jointes, liens

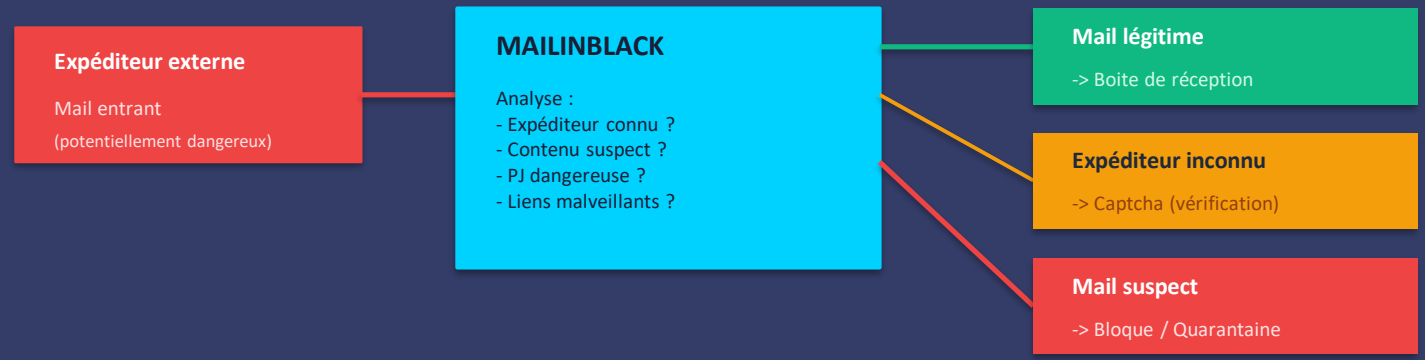
Captcha humain

Les expéditeurs inconnus doivent prouver qu'ils sont humains (pas un robot)

Interface simple

Chaque collaborateur gère sa liste blanche / noire depuis un portail web

Fonctionnement de Mailinblack



Menaces bloquées par Mailinblack

Phishing (hameçonnage)

Faux e-mails imitant une banque, un fournisseur ou un client pour voler des identifiants

Ransomware

Pieces jointes infectées qui chiffrent vos fichiers et demandent une rançon

Spear phishing (attaque ciblée)

Mail personnalise visant un collaborateur précis (ex : faux mail du dirigeant demandant un virement)

Spam / Publicité

Mails indésirables qui polluent les boites et font perdre du temps

Risques dans les e-mails & bonnes pratiques

Même avec Mailinblack, la vigilance humaine reste indispensable

MOTS-CLES A EVITER dans les e-mails

Ne JAMAIS écrire dans un objet ou corps de mail :

RIB, IBAN, coordonnées bancaires, numéro de compte

Ne JAMAIS mettre en pièce jointe :

Fichier nomme 'RIB', 'IBAN', ‘pièce identité', 'justificatif',
'carte identité', 'passeport', 'bulletin salaire'

Pourquoi ?

Les robots (bots) scannent les mails a la recherche de ces mots-clés.
Un mail contenant 'RIB' + une PJ PDF est une cible prioritaire pour les pirates.

Alternative sécurisée

Nommer les fichiers de manière neutre : 'Document_compta_mars.pdf'
Ou utiliser un espace sécurise de partage (coffre-fort numérique)

Données sensibles : procédure de confirmation

Règle d'or

Toute transmission de données bancaires, RIB ou coordonnées
sensibles doit être confirmée par téléphone avec le destinataire.

Procédure recommandée

1. Envoyer le document par mail (nom neutre, sans mot-clé)
2. Le client confirme la réception
3. Demander aux clients de confirmer les infos par téléphone
4. Ne JAMAIS répondre a une demande de RIB par mail sans appel

Cas concret de fraude

Un pirate intercepte un mail et modifie le RIB d'un fournisseur.
Sans vérification téléphonique, le paiement part chez le pirate.
Ce type de fraude coute en moyenne 30 000 a 100 000 EUR par incident.

Bonnes habitudes a adopter au quotidien

Vérifier l’expéditeur

Toujours vérifier l'adresse complète (pas juste le nom affiche). contact@goiran.fr =/= contact@goiran-facture.com

Ne jamais cliquer en urgence

Les mails pirates créent un sentiment d'urgence ('Votre compte sera ferme dans 24h'). Prendre le temps de vérifier.

Signaler les mails suspects

Utiliser le bouton Mailinblack pour signaler un mail douteux. Ne pas le transférer a un collègue.

Ne pas ouvrir les PJ inattendues

Un fournisseur envoie une facture que vous n'attendez pas ? Vérifier par téléphone avant d'ouvrir.

Séparer pro et perso

Ne jamais utiliser sa boite mail professionnelle pour des inscriptions personnelles (sites marchands, réseaux sociaux).

Mots de passe uniques

Ne JAMAIS envoyer un mot de passe par e-mail. Utiliser KeePass (voir Partie 3).

Toujours accepter la double authentification quand celle-ci est disponible

— Mailinblack + Bons reflexes

MAILINBLACK — Mode d'emploi

Un mail est en quarantaine ?

Connectez-vous au portail Mailinblack
Vérifiez l'expéditeur > Si légitime : libérez le mail
Si douteux : laissez-en quarantaine

Un expéditeur est toujours bloqué ?

Ajoutez-le a votre liste blanche
(Portail > Mon compte > Liste blanche > Ajouter)

Vous recevez un mail suspect ?

Ne cliquez sur AUCUN lien
Ne téléchargez AUCUNE pièce jointe
Signalez-le via le bouton Mailinblack

Un collègue vous transfère un mail suspect ?

Ne l'ouvrez pas ! Demandez-lui de le signaler.
Transférer un mail suspect = propager le risque

Vous avez clique sur un lien douteux ?

Prévenez IMMEDIATEMENT le service informatique
Changez votre mot de passe
Ne pas éteindre le poste (pour analyse)

BONS REFLEXES — A retenir

1. Toujours vérifier l'adresse e-mail complète de l'expéditeur
2. Ne JAMAIS envoyer de RIB, IBAN ou données bancaires par mail
3. Nommer les pièces jointes de manière neutre (pas 'RIB.pdf')
4. Confirmer par téléphone tout échange de données sensibles
5. Ne JAMAIS cliquer sur un lien dans un mail 'urgent'
6. Signaler tout mail suspect via Mailinblack (ne pas le transférer)
7. Ne pas ouvrir une pièce jointe inattendue sans vérification
8. Utiliser des mots de passe uniques et forts (voir KeePass)
9. Séparer mails professionnels et inscriptions personnelles
10. En cas de doute : NE RIEN FAIRE et appeler le service IT

KeePass — Gestionnaire de mots de passe

Solution open-source, certifiée ANSSI, pour sécuriser tous les accès

Qu'est-ce que KeePass ?

Coffre-fort numérique

Stocke tous les mots de passe dans un fichier chiffre (.kdbx)

1 seul mot de passe maitre

L'utilisateur ne retient qu'un seul mot de passe pour tout déverrouiller

Certifie ANSSI

Recommande par l'Agence Nationale de la Sécurité des Systèmes d'Information

Gratuit et open-source

Pas de cout de licence, code source auditable

Pourquoi KeePass ?

Fini les post-it

Plus de mots de passe écrits sur papier ou dans un fichier Excel

Mots de passe uniques

Générateur intègre : un mot de passe différant par accès

Sécurité maximale

Chiffrement AES-256 (standard militaire)

Multi-plateforme

Windows, Mac, Linux, Android, iOS

Stockage des données

Fichier local chiffre

Base .kdbx stockée sur P: Société
(accessible par le collaborateur uniquement)

Sauvegarde automatique

Inclus dans la sauvegarde quotidienne
(NAS + disque externe + cloud)

Aucun cloud externe

Pas de stockage chez un tiers
Données 100% maitrisées en interne

Déploiement prévu (exemple)

Phase 1 — Installation (Semaine 1)

- Installer KeePass sur tous les postes via GPO
- Créer un fichier .kdbx par collaborateur
- Définir le mot de passe maitre avec chaque collaborateur

Phase 2 — Migration (Semaines 2-3)

- Recenser tous les accès de chaque collaborateur
- Migrer les mots de passe existants dans KeePass
- Supprimer les anciens stockages (post-it, Excel, navigateur)

Phase 3 — Formation (Semaine 4)

- Formation individuelle de 30 min par collaborateur
- Distribution du cheat sheet (fiche pratique)
- Support IT disponible pendant 2 semaines

Gestion centralisée (service IT)

Base partagée IT

Le service informatique dispose d'une base KeePass dédiée
contenant les accès d'administration (serveurs, AD, firewall, NAS...)

Accès de secours

En cas d'absence du technicien IT, une copie de la base IT
est stockée dans un coffre (chiffrée + mot de passe scelle)

KeePass + Fichier clé

Pour les accès les plus sensibles (AD, firewall) :
Double authentification = mot de passe maitre + fichier clé (.keyx)
Le fichier clé est stocke sur un support sépare (clé USB)

Alternative future

Si besoin de gestion multi-utilisateurs avancée :
Envisager Bitwarden (auto-héberge) ou Vaultwarden
pour un partage sécurise entre plusieurs techniciens

Accès personnalisés aux postes de travail

Un mot de passe unique par collaborateur et par accès

Situation actuelle — Risque

Mots de passe partages

Plusieurs collaborateurs utilisent le même identifiant/mot de passe sur les postes de travail

Impossible de tracer

En cas d'incident, impossible de savoir qui a fait quoi

Départ d'un collaborateur

Il connait les mots de passe de tout le monde
-> Il faudrait tout changer a chaque départ

Solution — 1 collaborateur = 1 compte

Compte Active Directory personnel

Chaque collaborateur a son propre login Windows (prénom. nom / mot de passe unique)

Traçabilité

Les actions sont enregistrées au nom de chaque utilisateur (connexions, modifications de fichiers, impressions)

Départ simplifie

Désactiver 1 compte AD = couper tous les accès immédiatement

Connexions distantes (TSE + VPN)

Accès VPN

Les collaborateurs extérieurs se connectent via VPN chiffre (porte d'accès sécurisée)

Bureau a distance (TSE/RDP)

Connexion au poste ou serveur de l'entreprise depuis l'extérieur via Remote Desktop

Authentification

Login AD personnel + mot de passe KeePass
Même identifiant qu'en local

Synthèse & actions a valider

Récapitulatif des mesures proposées

Action	Description	Cout estime	Ressources	
Séparation NAS	Déplacer le NAS dans un bâtiment sépare	Faible	Cable réseau / Wi-Fi	RECOMMANDE
Rotation disques externes	Achat d'un 2eme disque + chiffrement BitLocker	350 EUR	1 disque dur externe	RECOMMANDE
Disque Quadra	Archivage Quadra pour libérer espace serveur/cloud	150 EUR	1 disque dur externe	RECOMMANDE
Bonnes pratiques mails	Sensibilisation équipes (RIB, PJ, vérification tel.)	0 EUR	Réunion + cheat sheet	RECOMMANDE
Déploiement KeePass	Installation + migration + formation collaborateurs	0 EUR (gratuit)	4 semaines (temps IT)	RECOMMANDE
Accès personnalisés	1 compte AD / 1 mot de passe par collaborateur	0 EUR	Configuration AD + KeePass	RECOMMANDE

COUT TOTAL ESTIME

Matériel : ~500 EUR (2 disques externes) | Logiciels : 0 EUR (KeePass gratuit, Mailinblack déjà en place)

Investissement minimal pour un gain de sécurité majeur.
La majorité des mesures ne coutent que du temps de configuration.

Ces mesures répondent aux recommandations de l'ANSSI.